

LAYERZERO · SECURITY REVIEW

LayerZero

Console EVM Updates.

A security review of Console EVM Updates.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
LayerZero	Console EVM Updates	Guardian	July 16 – July 21, 2026	July 27, 2026

§ 00

Contents.

15 pages — overview, confidence ranking, scope, 4 findings, disclaimer, and about Guardian.

§ 01	Overview	P. 03
§ 02	Confidence Ranking	P. 04
§ 03	Scope & Classifications	P. 05
	Files in Scope	P. 06
§ 04	Findings	P. 08
	Main Review · 4 findings	P. 09
§ 05	Disclaimer	P. 14
§ 06	About Guardian	P. 15

§ 01

Overview.

Guardian reviewed Console EVM Updates across a single review round. The final report includes 1 Low, 3 Informational findings.

AUDIT FIRM	REPOSITORY
Guardian	LayerZero-Labs/audit-external
CLIENT	METHODOLOGY
LayerZero	Smart contract · Manual · Main Review
PROJECT	MAIN REVIEW COMMIT
Console EVM Updates	6113ab299c04
PREPARED BY	
Guardian	
AUDIT WINDOW	
July 16 – July 21, 2026	
FINAL REPORT	
July 27, 2026	

1.1 Confidence Ranking

5 / 5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	0	0	0	0	0
High	0	0	0	0	0
Medium	0	0	0	0	0
Low	1	0	0	0	1
Informational	3	0	1	0	2
All severities	4	0	1	0	3

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed Console EVM Updates in `LayerZero-Labs/audit-external`. The scope includes 3,013 source lines across 67 files.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH
Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM
Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW
Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH
Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM
Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW
Unlikely to ever occur in production.

Files in Scope 1/2.

FILE	NSLOC	TOTAL
apps/oapp-app/contracts/evm/non-upgradeable-next/contracts/oapp/libs/OptionsBuilder.sol	74	181
apps/oapp-app/contracts/evm/upgradeable-next/contracts/oapp/alt/0AppAltUpgradeable.sol	20	48
apps/oapp-app/contracts/evm/upgrading-channel/0AppMessagingChannelBaseUpgradeable.sol	19	76
apps/oapp-app/contracts/evm/upgrading-channel/0AppMessagingChannelRBACUpgradeable.sol	27	70
apps/oapp-app/contracts/evm/upgrading-msg-inspection/0AppMsgInspectionBaseUpgradeable.sol	26	67
apps/oapp-app/contracts/evm/upgrading-msg-inspection/0AppMsgInspectionRBACUpgradeable.sol	11	34
apps/oapp-app/contracts/evm/upgradeable-next/contracts/oapp/0AppCoreBaseUpgradeable.sol	47	114
apps/oapp-app/contracts/evm/upgradeable-next/contracts/oapp/0AppCoreRBACUpgradeable.sol	19	71
apps/oapp-app/contracts/evm/upgradeable-next/contracts/oapp/0AppReceiverUpgradeable.sol	26	118
apps/oapp-app/contracts/evm/upgradeable-next/contracts/oapp/0AppSenderUpgradeable.sol	44	130
apps/oapp-app/contracts/evm/upgradeable-next/contracts/oapp/0AppUpgradeable.sol	12	45
apps/oapp-app/contracts/evm/upgrading-options-type-3/0AppOptionsType3BaseUpgradeable.sol	50	122
apps/oapp-app/contracts/evm/upgrading-options-type-3/0AppOptionsType3RBACUpgradeable.sol	11	34
apps/oft-app/contracts/evm/non-upgradeable-next/contracts/libs/OFTComposeMsgCodec.sol	31	85
apps/oft-app/contracts/evm/non-upgradeable-next/contracts/libs/OFTMsgCodec.sol	29	78
apps/oft-app/contracts/evm/non-upgradeable-next/contracts/utils/OFTDecimalUtils.sol	33	88
apps/oft-app/contracts/evm/upgrading-extended/alt/OFTBurnMintExtendedRBACAltUpgradeable.sol	28	52
apps/oft-app/contracts/evm/upgrading-extended/alt/OFTBurnSelfMintExtendedRBACAltUpgradeable.sol	26	50
apps/oft-app/contracts/evm/upgrading-extended/alt/OFTLockUnlockExtendedRBACAltUpgradeable.sol	14	33
apps/oft-app/contracts/evm/upgrading-extended/contracts/extended/OFTBurnMintExtendedRBACUpgradeable.sol	63	162
apps/oft-app/contracts/evm/upgrading-extended/contracts/extended/OFTBurnSelfMintExtendedRBACUpgradeable.sol	34	77
apps/oft-app/contracts/evm/upgrading-extended/contracts/extended/OFTCoreExtendedRBACUpgradeable.sol	96	170
apps/oft-app/contracts/evm/upgrading-extended/contracts/extended/OFTLockUnlockExtendedRBACUpgradeable.sol	43	93
apps/oft-app/contracts/evm/upgrading-extended/contracts/extended/OFTNativeExtendedRBACUpgradeable.sol	57	134
apps/oft-app/contracts/evm/upgradeable-next/contracts/oft/OFTCoreBaseUpgradeable.sol	122	344
apps/oft-app/contracts/evm/upgradeable-next/contracts/oft/OFTCoreRBACUpgradeable.sol	21	52
apps/project-types/console-oft-next-app/contracts/evm/contracts/alt/OFTBurnMintAlt.sol	23	33
apps/project-types/console-oft-next-app/contracts/evm/contracts/alt/OFTBurnSelfMintAlt.sol	21	31
apps/project-types/console-oft-next-app/contracts/evm/contracts/alt/OFTLockUnlockAlt.sol	9	19
apps/project-types/console-oft-next-app/contracts/evm/contracts/ERC20Plus.sol	49	118
apps/project-types/console-oft-next-app/contracts/evm/contracts/OFTBurnMint.sol	23	45
apps/project-types/console-oft-next-app/contracts/evm/contracts/OFTBurnSelfMint.sol	21	45
apps/project-types/console-oft-next-app/contracts/evm/contracts/OFTLockUnlock.sol	9	19
apps/project-types/console-oft-next-app/contracts/evm/contracts/OFTNative.sol	9	19
apps/project-types/nexus-next-app/contracts/extensions/OFTRegistryBaseUpgradeable.sol	89	189
apps/project-types/nexus-next-app/contracts/extensions/OFTRegistryRBACUpgradeable.sol	16	50

Files in Scope 2/2.

FILE	NSLOC	TOTAL
apps/project-types/nexus-next-app.../contracts/extensions/TokenScalesBaseUpgradeable.sol	41	107
apps/project-types/nexus-next-app/contracts/evm/contracts/libs/NexusMsgCodec.sol	35	111
apps/project-types/nexus-next-app...racts/evm/contracts/modules/NexusFeeConfigModule.sol	83	172
apps/project-types/nexus-next-app/contracts/evm/contracts/modules/NexusModule.sol	34	92
apps/project-types/nexus-next-app/contracts/evm/contracts/modules/NexusPauseModule.sol	98	197
apps/project-types/nexus-next-app...cts/evm/contracts/modules/NexusRateLimiterModule.sol	54	121
apps/project-types/nexus-next-app/contracts/evm/contracts/Nexus.sol	274	574
apps/project-types/nexus-next-app/contracts/evm/contracts/NexusAlt.sol	17	46
apps/project-types/nexus-next-app/contracts/evm/contracts/NexusERC20.sol	74	168
apps/project-types/nexus-next-app/contracts/evm/contracts/NexusERC20Guard.sol	22	47
apps/project-types/nexus-next-app/contracts/evm/contracts/Nexus0FT.sol	80	167
apps/project-types/nexus-next-app/contracts/evm/contracts/Nexus0FTAlt.sol	38	73
apps/proxy-app/contracts/evm/proxy-v5-next-evm/contracts/ProxyAdmin2Step.sol	17	39
apps/proxy-app/contracts/evm/prox...t-evm/contracts/TransparentUpgradeableProxy2Step.sol	31	109
contracts/common/utils/evm/upgrad...t/contracts/access/AccessControl2StepUpgradeable.sol	68	144
contracts/common/utils/evm/upgrad...ext/contracts/allowlist/AllowlistBaseUpgradeable.sol	94	184
contracts/common/utils/evm/upgrad...ext/contracts/allowlist/AllowlistRBACUpgradeable.sol	19	55
contracts/common/utils/evm/upgrad...ts/credit-redirect/CreditRedirectBaseUpgradeable.sol	45	103
contracts/common/utils/evm/upgrad...ts/credit-redirect/CreditRedirectRBACUpgradeable.sol	11	35
contracts/common/utils/evm/upgrad...ntracts/fee-accounting/FeeHandlerBaseUpgradeable.sol	29	69
contracts/common/utils/evm/upgrad...ntracts/fee-accounting/FeeHandlerRBACUpgradeable.sol	11	34
contracts/common/utils/evm/upgrad...xt/contracts/fee-config/FeeConfigBaseUpgradeable.sol	54	125
contracts/common/utils/evm/upgrad...xt/contracts/fee-config/FeeConfigRBACUpgradeable.sol	15	44
contracts/common/utils/evm/upgradeable-next/contracts/libs/EnumerableSetPagination.sol	36	69
contracts/common/utils/evm/upgrad...t/contracts/pause-by-id/PauseByIDBaseUpgradeable.sol	55	127
contracts/common/utils/evm/upgrad...t/contracts/pause-by-id/PauseByIDRBACUpgradeable.sol	30	74
contracts/common/utils/evm/upgradeable-next/contracts/pause/PauseBaseUpgradeable.sol	43	107
contracts/common/utils/evm/upgradeable-next/contracts/pause/PauseRBACUpgradeable.sol	16	47
contracts/common/utils/evm/upgrad...ext/contracts/rate-limiter/libs/RateLimiterUtils.sol	36	70
contracts/common/utils/evm/upgrad...ontracts/rate-limiter/RateLimiterBaseUpgradeable.sol	272	590
contracts/common/utils/evm/upgrad...ontracts/rate-limiter/RateLimiterRBACUpgradeable.sol	29	81

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
L-01	OFT interface ID omits receiver functions	Unexpected Behavior	LOW	RESOLVED	p. 9
I-01	Divergent guards can block Nexus credits	Unexpected Behavior	INFORMATIONAL	ACKNOWLEDGED	p. 10
I-02	Empty init data leaves proxy unprotected	Informational	INFORMATIONAL	RESOLVED	p. 12
I-03	Burn docs omit nonce eligibility	Documentation	INFORMATIONAL	RESOLVED	p. 13

LOW **L-01**

RESOLVED

OFT interface ID omits receiver functions

CATEGORY Unexpected Behavior

LOCATION <https://github.com/GuardianOrg/layerzero-console-oft-nexus-next-audit-scope-2026-07-15-team1-1784123035999/blob/6113ab299c04457e8fcc539e6214ba6b218c34c2/apps/oa-app-app/contracts/evm/non-upgradeable-next/contracts/interfaces/IAppExtended.sol#L23-L28>

REVIEW Main Review

DESCRIPTION

`OAPP_EXTENDED_INTERFACE_ID` is intended to flatten the complete OApp interface tree. However, it includes `type(IAppReceiver).interfaceId` without separately including its parent, `ILayerZeroReceiver`. Solidity calculates an interface ID using only functions declared directly by that interface. Consequently, `type(IAppReceiver).interfaceId` includes `isComposeMsgSender` but excludes the inherited `allowInitializePath`, `nextNonce`, and `lzReceive` functions.

```
/// @dev Flatten all leaf interface IDs.  
bytes4 constant OAPP_EXTENDED_INTERFACE_ID = type(IAppReceiver).interfaceId ^  
type(IAppMessagingChannel).interfaceId ^  
type(IAppCore).interfaceId ^  
type(IAppOptionsType3).interfaceId ^  
type(IAppMsgInspection).interfaceId;
```

The incomplete OApp ID propagates into `OFT_EXTENDED_INTERFACE_ID`. The contract currently returns `0x97b6b900`, whereas the complete flattened interface ID is `0x06fbb406`. The difference is exactly the omitted `ILayerZeroReceiver` interface ID.

Integrations that independently calculate the identifier from the complete ABI may reject or misidentify compatible OFT deployments.

RECOMMENDATION

Include `type(ILayerZeroReceiver).interfaceId` when calculating `OAPP_EXTENDED_INTERFACE_ID`.

RESOLUTION

Status: Resolved.

INFORMATIONAL I-01

ACKNOWLEDGED

Divergent guards can block Nexus credits

CATEGORY Unexpected Behavior

LOCATION <https://github.com/GuardianOrg/layerzero-console-oft-nexus-next-audit-scope-2026-07-15-team1-1784123035999/blob/6113ab299c04457e8fcc539e6214ba6b218c34c2/contracts/common/utils/evm/upgradeable-next/contracts/credit-redirect/CreditRedirectBaseUpgradeable.sol#L63-L84> <https://github.com/GuardianOrg/layerzero-console-oft-nexus-next-audit-scope-2026-07-15-team1-1784123035999/blob/6113ab299c04457e8fcc539e6214ba6b218c34c2/apps/project-types/nexus-next-app/contracts/evm/contracts/Nexus.sol#L465-L480> <https://github.com/GuardianOrg/layerzero-console-oft-nexus-next-audit-scope-2026-07-15-team1-1784123035999/blob/6113ab299c04457e8fcc539e6214ba6b218c34c2/apps/project-types/nexus-next-app/contracts/evm/contracts/NexusERC20.sol#L82-L114>

REVIEW Main Review

DESCRIPTION

Nexus processes inbound transfers for multiple registered tokens using a single global `CreditRedirectStorage` configuration. However, each registered NexusERC20 stores an independent guard pointer that its administrator can replace through `setGuard`. When an inbound message is executed, Nexus first determines the effective recipient using the global allowlist.

```
if (!_isAllowlisted(_to)) {  
    /// @dev 'escrow' is guaranteed to be non-zero here.  
    address escrow = _getCreditRedirectStorage().escrow;  
    emit CreditRedirected(_to, escrow, _amountLD);  
    return escrow;  
}  
return _to;
```

If the global allowlist considers the intended recipient eligible, `_redirectCredit` returns the original recipient instead of the escrow address. Next, Nexus invokes the registered NexusERC20's `mint` function. Before minting, NexusERC20 performs another validation using that token's current guard. If the global allowlist and the token's current guard contain different policies, the global allowlist may accept a recipient that the token guard rejects. In that case, Nexus does not redirect the credit to escrow because `_redirectCredit` returns the original recipient, but the subsequent guard check reverts the mint. Consequently, the sender's tokens have already been burned on the source chain and remain temporarily unavailable while the destination message is pending.

Although the intended deployment uses one shared guard for all Nexus tokens, this relationship is not enforced during token registration, credit redirect configuration, or subsequent guard replacement.

I-01 Divergent guards can block Nexus credits

CONTINUED

— RECOMMENDATION

Consider enforcing that Nexus's credit-redirect allowlist remains compatible with every registered NexusERC20 guard.

— RESOLUTION

Status: Acknowledged.

INFORMATIONAL I-02

RESOLVED

Empty init data leaves proxy unprotected

CATEGORY	Informational
LOCATION	https://github.com/GuardianOrg/layerzero-console-oft-nexus-next-audit-scope-2026-07-15-team1-1784123035999/blob/6113ab299c04457e8fcc539e6214ba6b218c34c2/apps/proxy-app/contracts/evm/proxy-v5-next-evm/contracts/TransparentUpgradeableProxy2Step.sol#L70-L74
REVIEW	Main Review

DESCRIPTION

TransparentUpgradeableProxy2Step forwards the caller-provided initialization data to the inherited ERC1967Proxy constructor. The pinned OpenZeppelin version permits this data to be empty, in which case the implementation is installed without initializing the proxy's storage.

If the implementation exposes an external initializer, it remains callable through the proxy. Because non-admin calls are delegated to the implementation, anyone can invoke the initializer before the legitimate administrator and assign themselves application ownership, roles, or other privileged configuration.

RECOMMENDATION

Require the proxy to be initialized atomically during deployment using the expected encoded initializer call. Consider upgrading to OpenZeppelin Contracts v5.6 or later, which rejects empty initialization data by default.

RESOLUTION

Status: Resolved.

INFORMATIONAL I-03

RESOLVED

Burn docs omit nonce eligibility

CATEGORY Documentation

LOCATION <https://github.com/GuardianOrg/layerzero-console-oft-nexus-next-audit-scope-2026-07-15-team1-1784123035999/blob/6113ab299c04457e8fcc539e6214ba6b218c34c2/apps/oa-pp-app/contracts/evm/non-upgradeable-next/contracts/interfaces/IOAppMessagingChannel.sol#L31-L38>

REVIEW Main Review

DESCRIPTION

The interface describes `burn` as removing a verified inbound nonce, implying that any verified packet can be burned with the correct payload hash. However, the Endpoint additionally requires the nonce to be at or below `lazyInboundNonce`.

```
if (curPayloadHash == EMPTY_PAYLOAD_HASH || _nonce > lazyInboundNonce[_oapp][_srcEid]
[_sender])
    revert Errors.LZ_InvalidNonce(_nonce);
```

Because verification does not advance `lazyInboundNonce`, burning a freshly verified packet will revert while its nonce remains above the lazy checkpoint.

The incomplete documentation may cause operators to submit reverting recovery transactions or misunderstand when `burn` is applicable.

RECOMMENDATION

Document that `burn` requires an exact, nonempty stored payload hash and `_nonce <= lazyInboundNonce`.

RESOLUTION

Status: Resolved.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

\$45B+DIGITAL ASSETS UNDER
REVIEW**200+**

ENGAGEMENTS COMPLETED

500+CRITICAL & HIGH FINDINGS
REPORTED

Reach us at audits@guardianaudits.com.